Project 1 Title: Secure Private Infrastructure Deployment with Bastion Access and IAM RoleBased Architecture

1. Project Overview

This project implements a production-grade secure AWS infrastructure for a fintech company. Application servers run in private subnets with no public IP, accessible only through a hardened Bastion Host. All EC2 instances use IAM Roles — no hardcoded credentials anywhere in the system.

2. Architecture Diagram

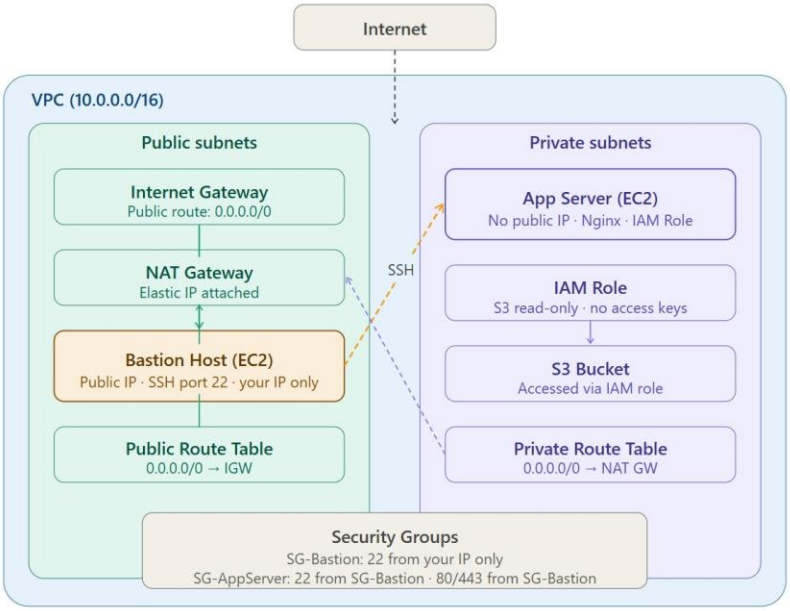

Figure 1 — architecture.png: Full AWS infrastructure layout (us-west-2)

Architecture Explanation

The infrastructure is built inside a custom VPC (fintech-vpc, vpc-0f37ec6ae5fe55c98) with CIDR 10.0.0.0/16 across two availability zones in us-west-2. Public subnets host the Bastion Host and NAT Gateway. Private subnets host the application server with no public IP and no direct internet route.

Traffic flow:

- Developer SSHs from local machine → Bastion Host (public subnet, IP-whitelisted on port 22)
- From Bastion (10.0.1.199), developer hops to App Server via private IP 10.0.3.108
- App Server reaches internet outbound-only via NAT Gateway (52.89.54.67)
- No inbound traffic from the internet can reach the private app server directly

Network Layout

Component	ID / Detail	CIDR / Value
fintech-vpc	vpc-0f37ec6ae5fe55c98	10.0.0.0/16
public-subnet-1	subnet-0752a6f323ceed782	10.0.1.0/24
public-subnet-2	subnet-00fb9854ec0d04038	10.0.2.0/24
private-subnet-1	subnet-04f832eb5d0a055cb	10.0.3.0/24
private-subnet-2	subnet-0fdc95f91346307b7	10.0.4.0/24
fintech-igw	igw-03bc679829d99a05d	Attached to fintech-vpc
fintech-nat-gw	nat-022d26bd503594c74	Public IP: 52.89.54.67
public-rt	rtb-05babe915393dcaa6	0.0.0.0/0 → IGW
private-rt	rtb-0b3b9ce01a54eb317	10.0.0.0/16 → local + NAT GW

3. Network Configuration Screenshots

3.1 VPC Details

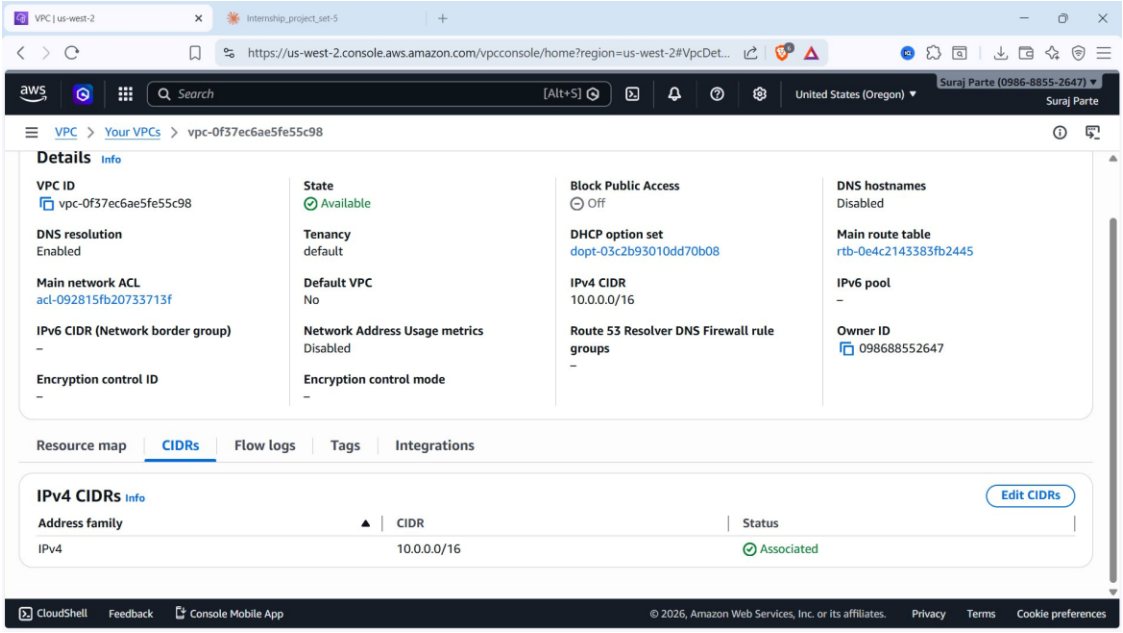

Figure 2 — 01_vpc_details.png: fintech-vpc (vpc-0f37ec6ae5fe55c98), CIDR 10.0.0.0/16, State: Available

3.2 Subnets List

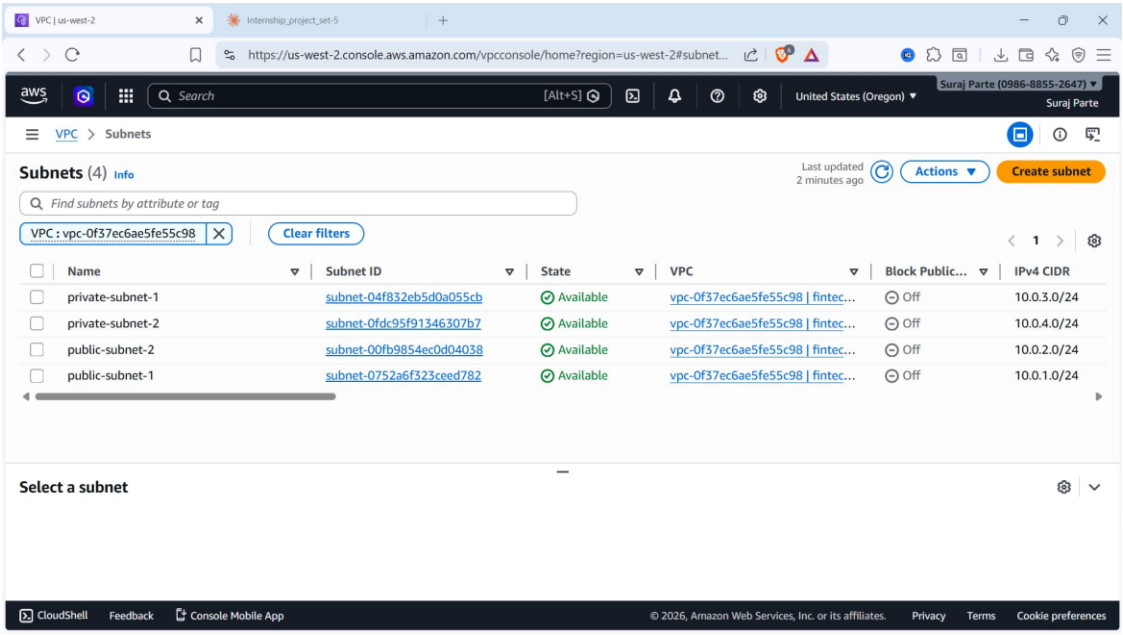

Figure 3 — 02_subnets_list.png: All 4 subnets (2 public, 2 private) in fintech-vpc — all Available

3.3 NAT Gateway

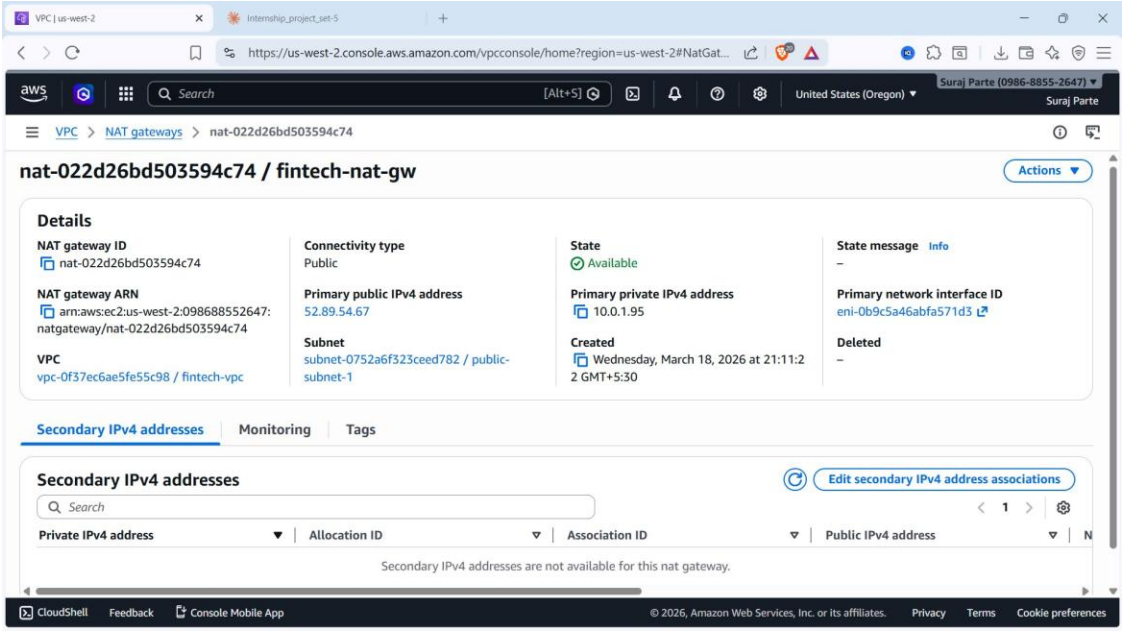

Figure 4 — 04_nat_gateway_available.png: fintech-nat-gw (nat-022d26bd503594c74) — State: Available, Public IP: 52.89.54.67, in public-subnet-1

3.4 Internet Gateway — Attached

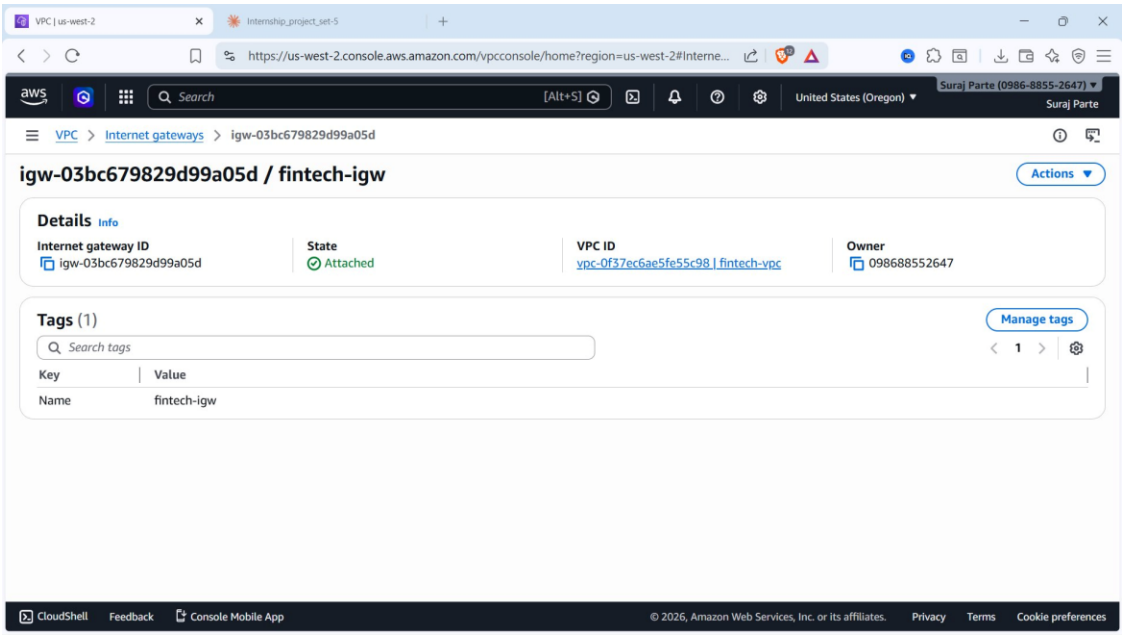

Figure 5 — 03_igw_attached.png: fintech-igw (igw-03bc679829d99a05d) — State: Attached to fintech-vpc

3.5 Public Route Table

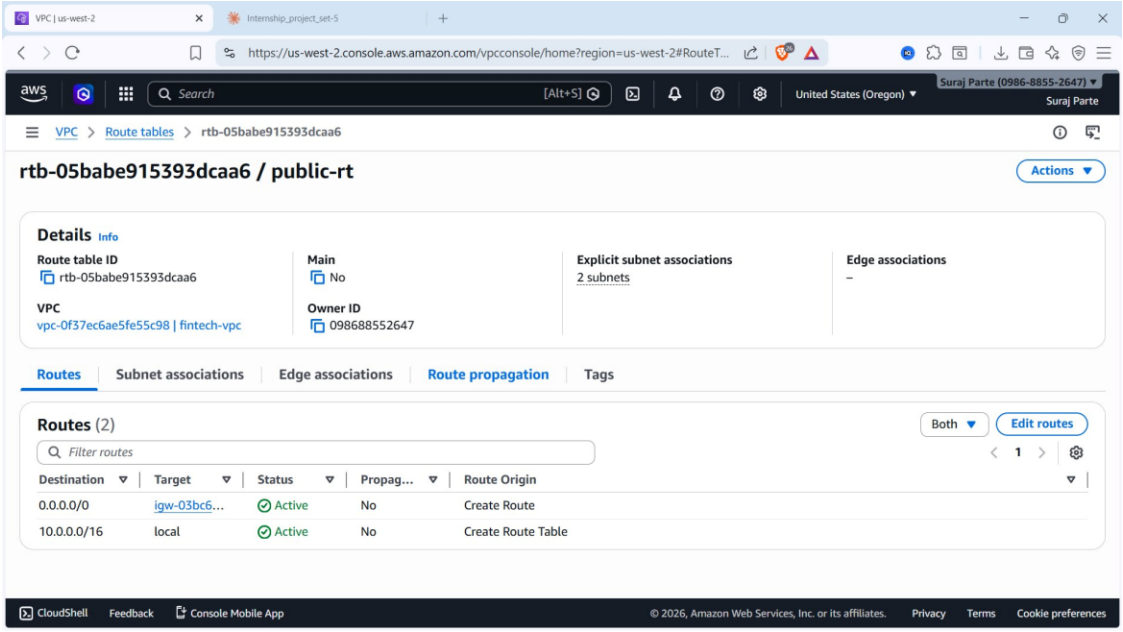

Figure 6 — 05_public_route_table.png: public-rt (rtb-05babe915393dcaa6) — Route 0.0.0.0/0 → IGW, 2 subnet associations

3.6 Private Route Table

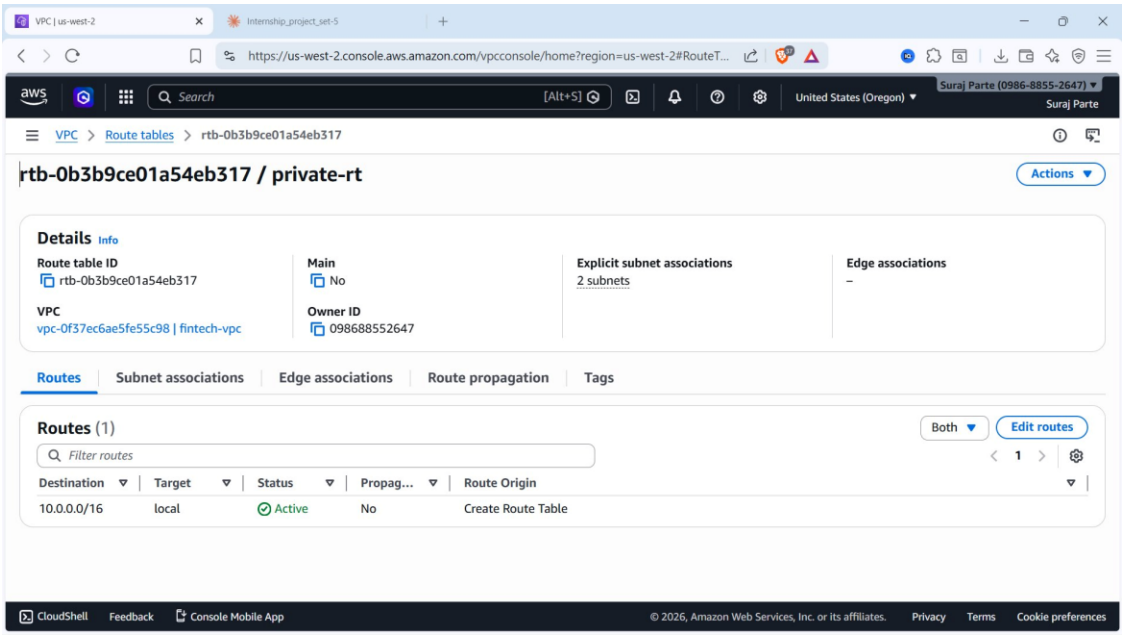

Figure 7 — 06_private_route_table.png: private-rt (rtb-0b3b9ce01a54eb317) — 10.0.0.0/16 local only, 2 subnet associations

4. Security Design Decisions

4.1 Bastion Host

- Deployed in public-subnet-1, Public IP 16.148.97.77 (instance i-053dc425d1536ab9f)
- SSH (port 22) restricted to your IP only — security group bastion-sg (sg-0651c18e2244fd108)
- Password login disabled — key-pair finetech-key.pem only
- Only 1 inbound rule exists — no other ports open

4.2 Private Application Server

- No public IP — private IP 10.0.3.108 only (instance i-04fdf0c9f8ced234f)
- Deployed in private-subnet-1 — unreachable from internet directly
- Security group appserver-sg (sg-0b22d17276040db6a) — SSH and HTTP from bastion-sg only
- Outbound routes through NAT Gateway — no direct internet exposure

4.3 Security Groups

Security Group	Rule	Source
bastion-sg (sg-0651c18e2244fd108)	SSH — Port 22	Your IP /32 only
appserver-sg (sg-0b22d17276040db6a)	SSH — Port 22	bastion-sg reference
appserver-sg (sg-0b22d17276040db6a)	HTTP — Port 80	bastion-sg reference

4.4 IAM Role

- Role ec2-role (arn:aws:iam::098688552647:role/ec2-role) with AmazonS3ReadOnlyAccess
- Attached to app-server via instance profile arn:aws:iam::098688552647:instance-profile/ec2-role
- No ~/.aws/credentials on server — temporary credentials via instance metadata

5. Security Group Configuration Screenshots

5.1 Bastion Security Group (bastion-sg)

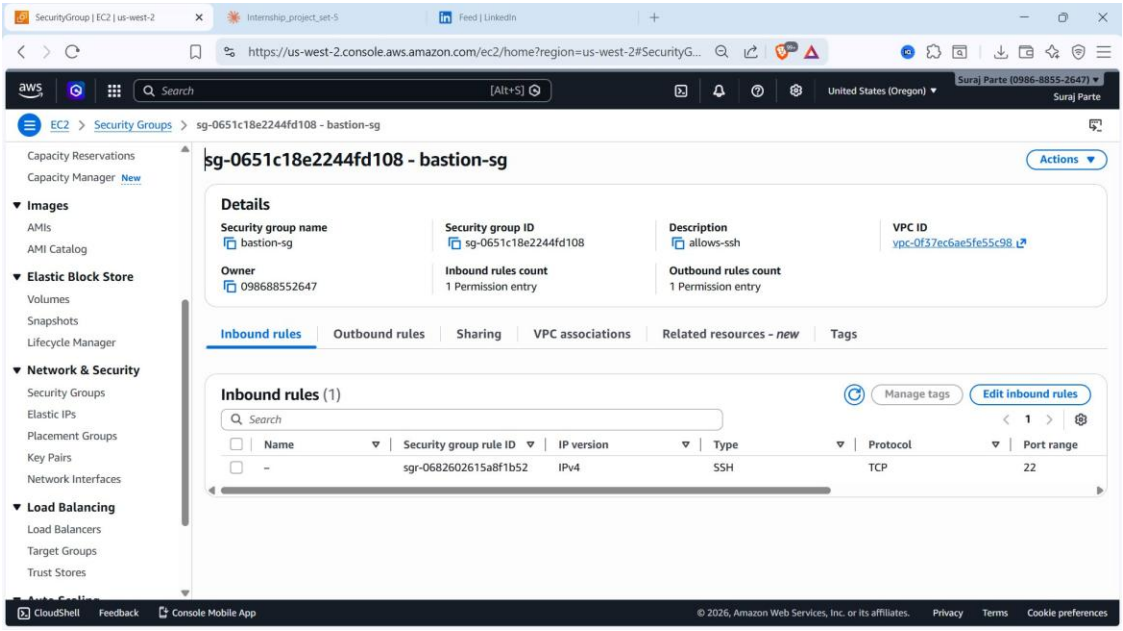

Figure 8 — 07_sg_bastion_inbound.png: bastion-sg — 1 inbound rule, SSH port 22, IPv4 only

5.2 App Server Security Group (appserver-sg)

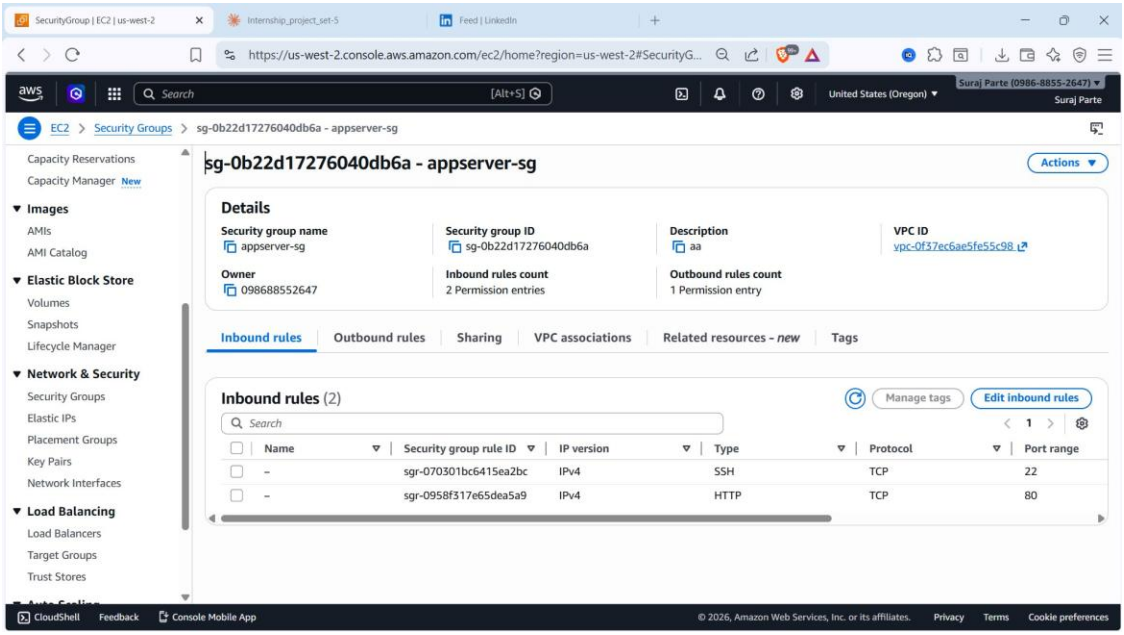

Figure 9 — 08_sg_appserver_inbound.png: appserver-sg — 2 inbound rules, SSH port 22 and HTTP port 80

6. Bastion Access Proof

6.1 Bastion Host EC2 Details

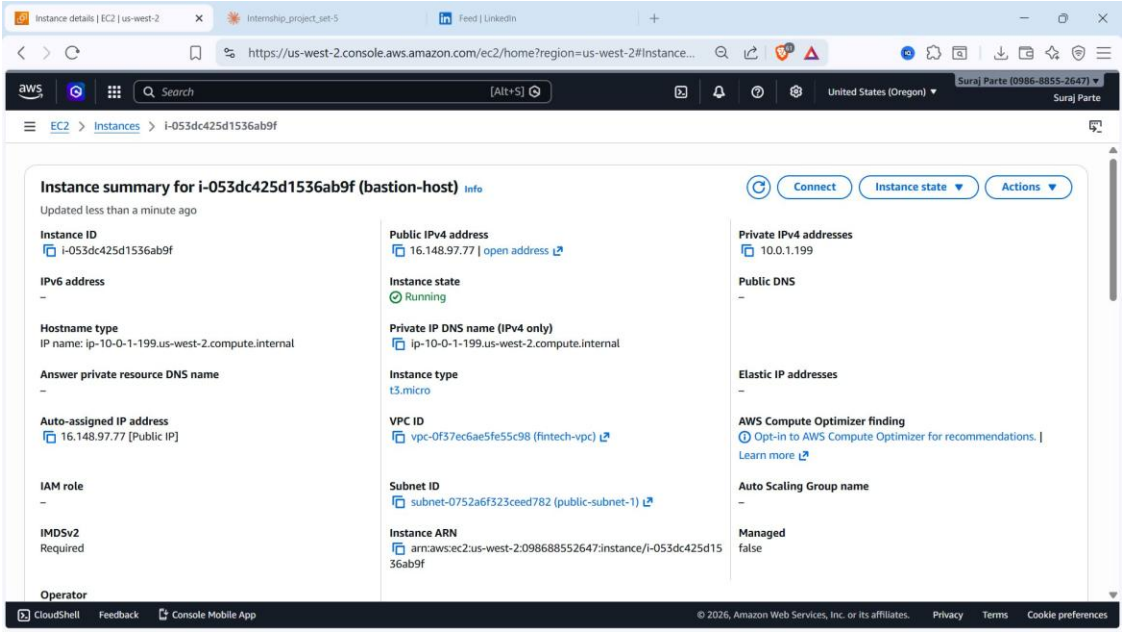

Figure 10 — 09_bastion_ec2_details.png: bastion-host (i-053dc425d1536ab9f) — Public IP 16.148.97.77, Subnet public-subnet-1, VPC fintech-vpc, Running

6.2 App Server EC2 Details

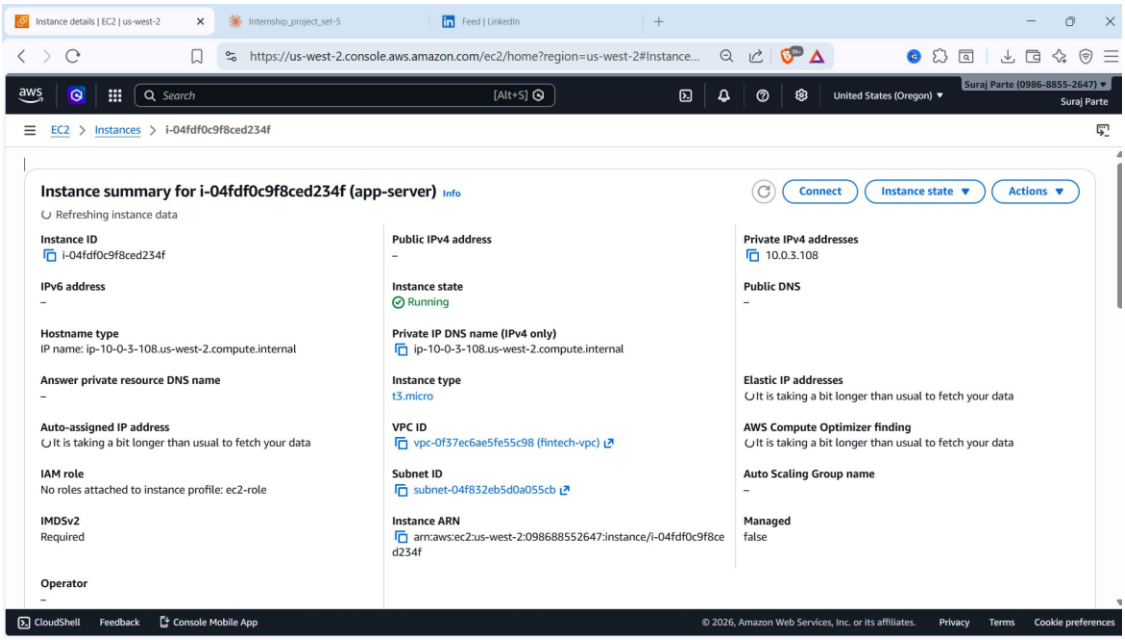

Figure 11 — 10_appserver_ec2_details.png: app-server (i-04fdf0c9f8ced234f) — No Public IP, Private IP 10.0.3.108, Subnet private-subnet-1, IAM role: ec2-role

6.3 Successful SSH — Bastion to App Server

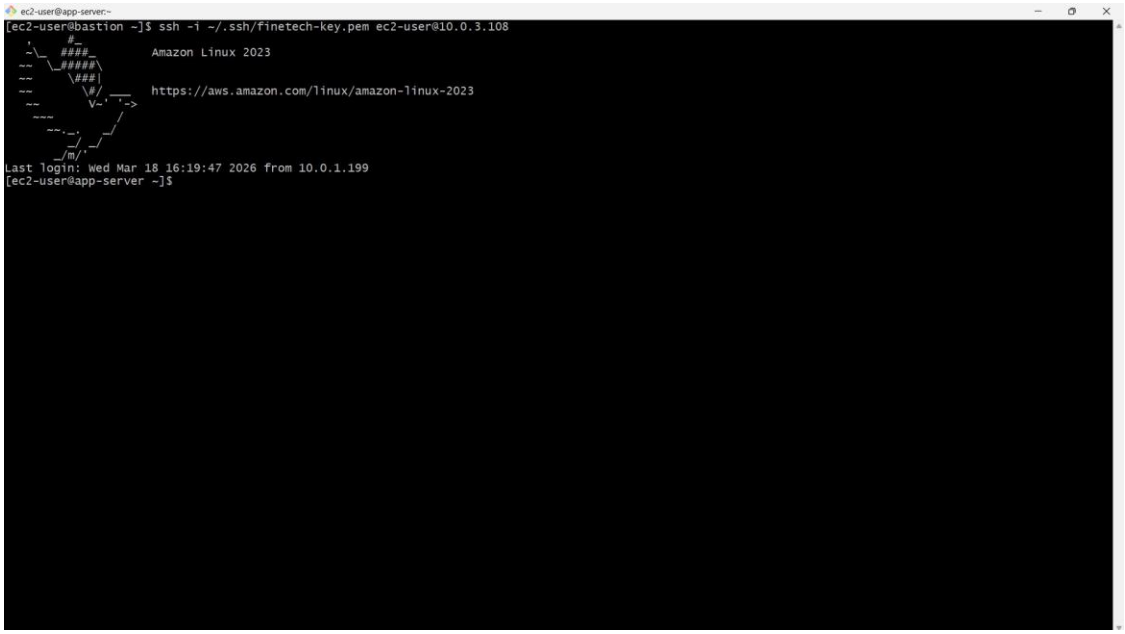

Figure 12 — 11_ssh_into_bastion.png: SSH from bastion (10.0.1.199) into app-server (10.0.3.108) — login successful, Amazon Linux 2023

6.4 Direct SSH Timeout — Security Validation

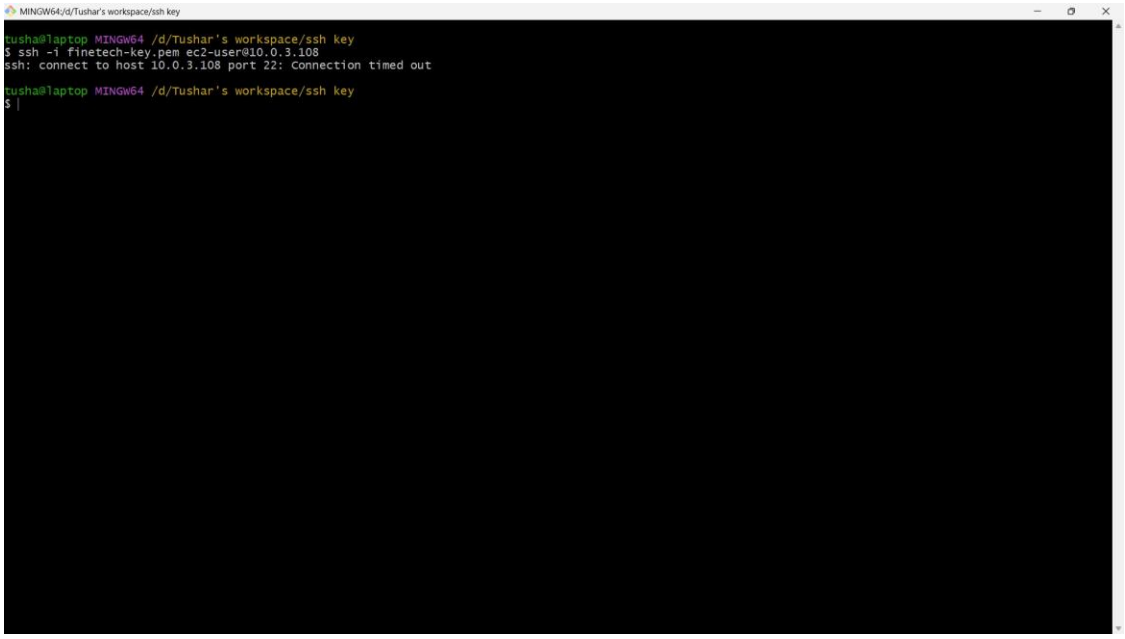

Figure 13 — 13_direct_ssh_timeout.png: Direct SSH to 10.0.3.108 from local machine — Connection timed out. Private server unreachable from internet.

7. IAM Role Attachment Proof

7.1 IAM Role Policy

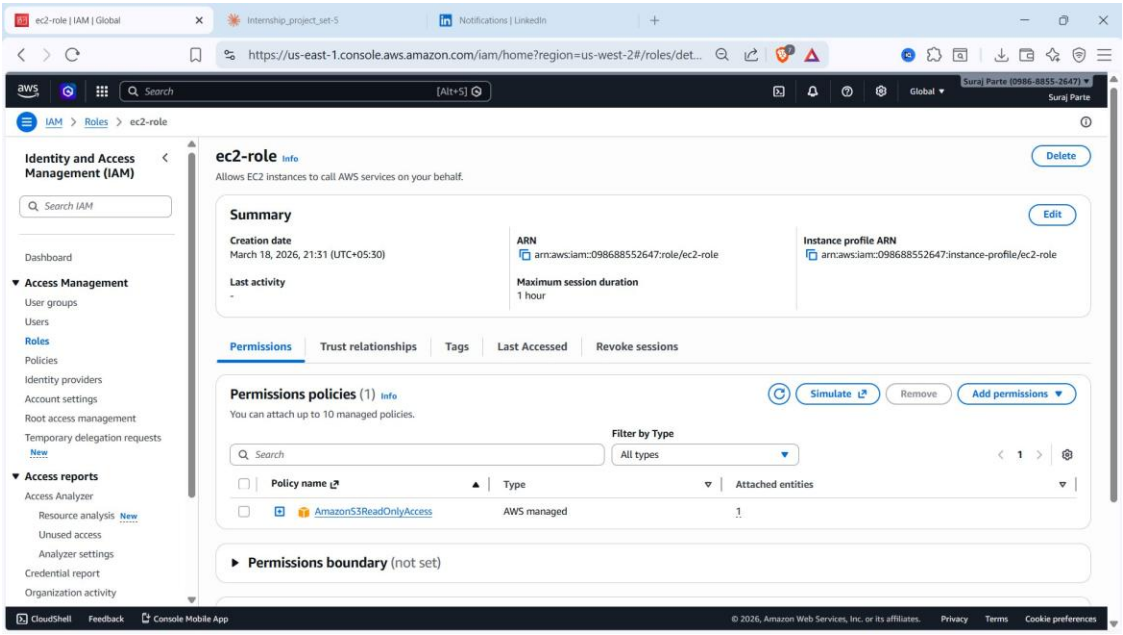

Figure 14 — 14_iam_role_policy.png: ec2-role with AmazonS3ReadOnlyAccess (AWS managed) — 1 attached entity

7.2 Role Attached to App Server

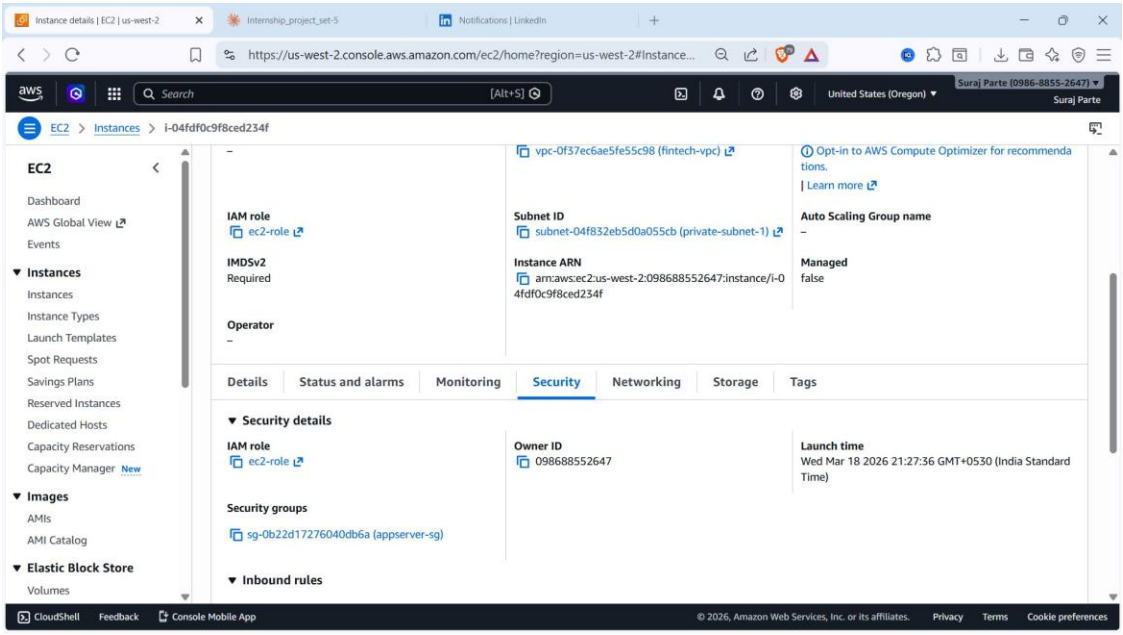

Figure 15 — 15_iam_role_attached_ec2.png: app-server Security tab — IAM role: ec2-role, Security group: appserver-sg, Subnet: private-subnet-1

8. Setup Steps Summary

Step	Action	Location
1	Create VPC fintech-vpc (10.0.0.0/16)	VPC Console
2	Create 4 subnets (2 public, 2 private)	VPC → Subnets
3	Create and attach Internet Gateway fintech-igw	VPC → Internet Gateways
4	Create NAT Gateway fintech-nat-gw in public-subnet-1	VPC → NAT Gateways
5	Create public-rt — 0.0.0.0/0 → IGW	VPC → Route Tables
6	Create private-rt — 0.0.0.0/0 → NAT GW	VPC → Route Tables
7	Create bastion-sg — SSH port 22 from your IP only	EC2 → Security Groups
8	Create appserver-sg — SSH + HTTP from bastion-sg	EC2 → Security Groups
9	Launch bastion-host in public-subnet-1 (public IP on)	EC2 → Launch Instance
10	Launch app-server in private-subnet-1 (no public IP)	EC2 → Launch Instance
11	Create ec2-role with S3ReadOnly, attach to app-server	IAM → Roles

10. Technologies Used

Technology	Purpose
Amazon VPC	Network isolation — custom CIDR, subnets, route tables
Amazon EC2	Bastion Host (t3.micro) and private application server (t3.micro)
Internet Gateway	Inbound/outbound internet access for public subnet resources
NAT Gateway	Outbound-only internet access for private subnet instances
IAM Roles	Credential-free AWS service access via instance profile
Amazon S3	Storage accessed via IAM role — no static access keys
Security Groups	Stateful firewall — enforces least privilege per resource

11. README

Project: Secure Private Infrastructure Deployment with Bastion Access and IAM Role-Based Architecture

Region: us-west-2 (Oregon) | Account: 098688552647 | Internship Project Set-5 — Project 1

Architecture Explanation

The infrastructure is designed around a custom VPC (fintech-vpc, 10.0.0.0/16) divided into four subnets across two availability zones in us-west-2. The public subnets (10.0.1.0/24 and 10.0.2.0/24) host the Bastion Host EC2 instance and the NAT Gateway. The private subnets (10.0.3.0/24 and 10.0.4.0/24) host the application server, which has no public IP address and no direct route to the internet.

Internet access for public resources is provided by the Internet Gateway (fintech-igw), which is attached to the VPC and referenced in the public route table with a default route (0.0.0.0/0 → IGW). The private route table does not reference the Internet Gateway at all — its default route points to the NAT Gateway, which means private instances can initiate outbound connections (for software updates or S3 access) but cannot receive any inbound connections from the internet.

All SSH access to the application server follows a strict jump-host pattern: a developer first connects to the Bastion Host using its public IP (16.148.97.77) from a whitelisted IP address, and from there connects to the application server using its private IP (10.0.3.108). The application server is completely isolated from any direct external access, as proven by the connection timeout when SSH is attempted directly from a local machine.

The IAM role (ec2-role) is attached to the application server as an instance profile. This allows the server to call AWS services such as S3 using temporary credentials automatically provisioned by the EC2 metadata service — no static access keys are stored anywhere on the server.

Security Design Decisions

The following security decisions were made throughout this project:

Private subnets for application servers.

Application servers must never be assigned a public IP. Placing them in private subnets with no Internet Gateway route means they are architecturally unreachable from the internet, regardless of security group configuration. Security groups alone are insufficient — subnet isolation is the correct first line of defence.

Bastion Host as the single SSH entry point.

A single hardened EC2 instance in the public subnet acts as the only SSH gateway into the private network. Its security group (bastion-sg) allows port 22 from only one specific IP address (/32 CIDR), eliminating exposure to the broader internet. Password authentication is disabled — only key-pair (finetech-key.pem) is accepted.

Security group chaining instead of IP-based rules.

The application server security group (appserver-sg) references bastion-sg as the SSH source rather than a static IP. This means only traffic that has already passed through the Bastion's security group can reach the app server. This is more robust than IP-based rules because it does not break if the Bastion's IP changes, and it cannot be spoofed by an external party claiming a matching IP.

IAM Instance Profile — zero hardcoded credentials.

Instead of configuring AWS access keys on the server, an IAM role (ec2-role) with AmazonS3ReadOnlyAccess is attached as an instance profile. The EC2 instance automatically receives short-lived credentials via the instance metadata endpoint (169.254.169.254). There is no credentials file on the server, nothing to rotate manually, and nothing that can be leaked through a misconfigured environment variable or committed to version control.

NAT Gateway for controlled outbound access.

Private instances need outbound internet access for OS updates and AWS API calls. The NAT Gateway provides this without creating any inbound attack surface — it performs source address translation for outbound traffic only. The private route table routes 0.0.0.0/0 to the NAT Gateway, not to the Internet Gateway.

Least privilege at every layer.

Each component has the minimum permissions required. The IAM role has read-only S3 access, not full S3 or admin access. Security groups allow only the ports explicitly needed (22 for SSH, 80 for HTTP). No wildcard sources (0.0.0.0/0) appear on any private resource.

Lessons Learned

- Private subnets and Bastion Hosts are a foundational AWS security pattern — it is not sufficient to rely on security groups alone to protect application servers from internet exposure.
- Security group chaining is significantly more secure and maintainable than IP-based source rules for internal east-west traffic within a VPC.

- IAM Instance Profiles completely eliminate the credential management problem for EC2 workloads — there is no justification for storing access keys on a server when roles are available.
- Route tables are the most critical control point in VPC design. A subnet is effectively public if it has a default route to an Internet Gateway, regardless of what security groups say.
- NAT Gateways must be placed in public subnets, not private subnets — a common mistake that results in private instances losing outbound connectivity entirely.
- Restricting Bastion SSH to a /32 IP is essential. Using 0.0.0.0/0 on a Bastion defeats the entire purpose of having one.
- The jump-host pattern (Local → Bastion → Private EC2) adds a second authentication and network boundary, making lateral movement significantly harder for an attacker even if one layer is compromised.
- Always verify that the private route table does not accidentally contain a route to the Internet Gateway — this mistake would expose private instances to inbound internet traffic.